

OWASP Dependency Check

The official overview link

[OWASP Dependency-Check | OWASP Foundation](#)

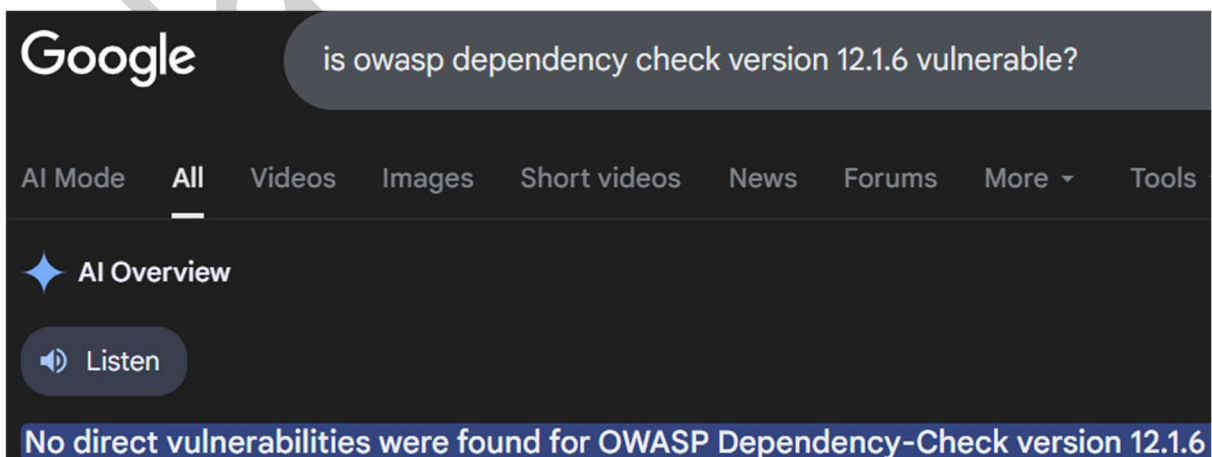
1. OWASP Installation

- **Version:** OWASP Dependency-Check **v12.1.6**
- **Source:** Installed from the official GitHub repository.

[GitHub - dependency-check/DependencyCheck: OWASP dependency-check is a software composition analysis utility that detects publicly disclosed vulnerabilities in application dependencies.](#)

2. OWASP Safety

- **Status:** Safe to use.



← ↻ <https://security.snyk.io/package/maven/org.owasp%3Adependency-check-cli/12.1.6>

See the full list of npm packages compromised in the "Shai-Hulud supply chain attack – Sep 2025" |

 **snyk** | SECURITY

org.owasp:dependency-check-cli@12.1.6 vulnerabilities

Direct Vulnerabilities

No direct vulnerabilities have been found for this package in Snyk's vulnerability database. This does not include vulnerabilities belonging to this package's dependencies.

[org.owasp:dependency-check-cli 12.1.6 vulnerabilities | Snyk](https://security.snyk.io/package/maven/org.owasp%3Adependency-check-cli/12.1.6)

3. First OWASP Scan

When you ran OWASP Dependency-Check for the **first time**, it downloaded a set of **vulnerability data feeds** i.e **National Vulnerability Database (NVD)** feeds from NIST

[NVD - Home](#)

4. Data Download Behavior for Multiple Pipelines

- When running Dependency-Check on **multiple pipelines** within the **same Jenkins node/agent**, the **downloaded CVE data is reused**.
- It does **not** download the entire dataset for every pipeline run on the same node/agent.

5. Data Update Mechanism on Jenkins Agents

- If vulnerability records already exist on a Jenkins agent and new updates are available on the NVD official site, OWASP Dependency-Check will **not** download all records again.
- It uses an **incremental update mechanism** to fetch only new or updated vulnerability data.

6. NVD API Key

- The NVD API key is a personal or organizational access key provided by the National Institute of Standards and Technology (NIST).
- Purpose: Allows automated tools such as Dependency-Check to fetch vulnerability data more efficiently from NVD.

Link to request NVD API Key:-

[NVD - API Key Request](#)

7. Benefits of Implementing the NVD API Key

- Once configured, Dependency-Check will **directly synchronize CVE records** from the official NVD website via their authenticated API.
- This ensures **fast, reliable, and up-to-date** vulnerability data retrieval.

8. Data Storage with NVD API Key Implementation

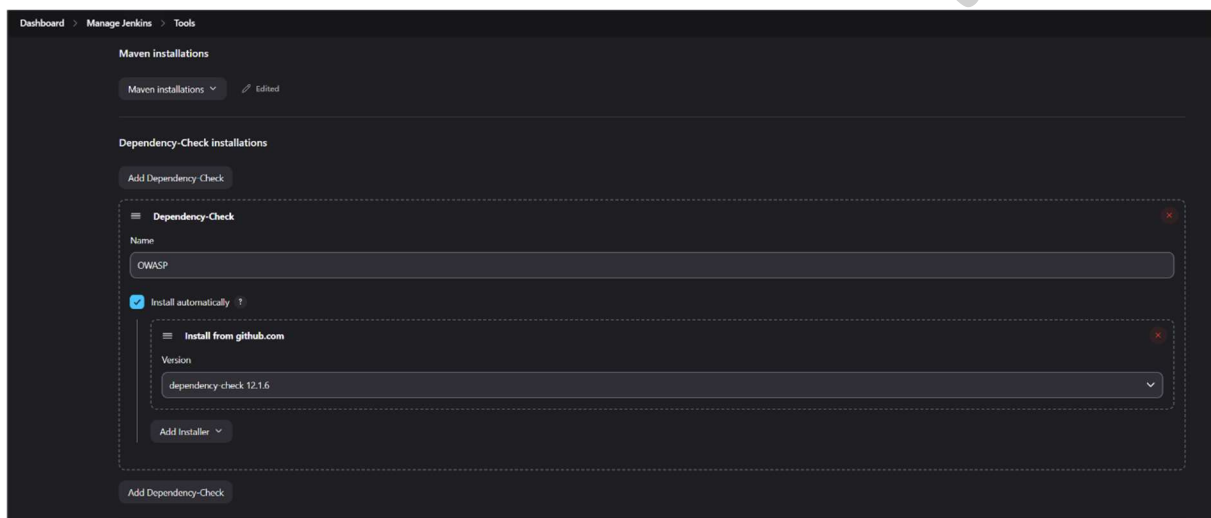
- Even with the NVD API key implemented, CVE records will still be **downloaded and stored locally** on the Jenkins agent.
- The key advantage is that downloads happen **faster and more reliably** from the official NVD servers.

9. Data Updates with NVD API Key

- When new vulnerability records are introduced by the NVD, OWASP Dependency-Check will **only download the new or updated records** rather than the entire dataset.

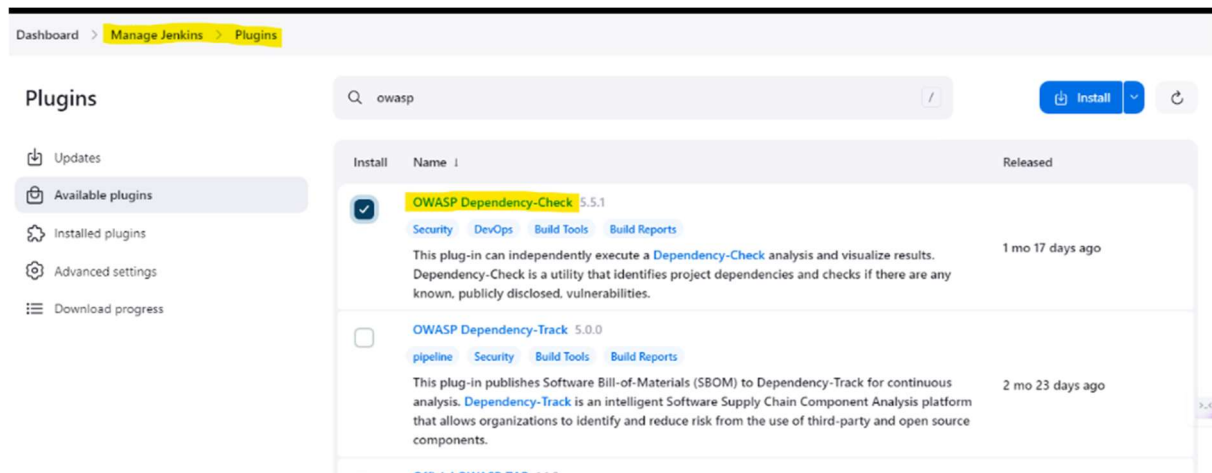
OWASP Installation

1. Install OWASP From Github in Jenkins



github :- [GitHub - dependency-check/DependencyCheck](https://github.com/dependency-check/DependencyCheck):
[OWASP dependency-check is a software composition analysis utility that detects publicly disclosed vulnerabilities in application dependencies.](https://github.com/dependency-check/DependencyCheck)

2. Install OWASP Dependencycheck Plugin



3. Request NVD-API-KEY

4. Setup NVD-API-KEY as Jenkins Secret

5. Use that secret in Jenkins Pipeline